Pause Gourmande

Document dédié à la sécurité de l'application

Architecture, protections Supabase, authentification, commandes, fidélité et notifications Push

Vue générale

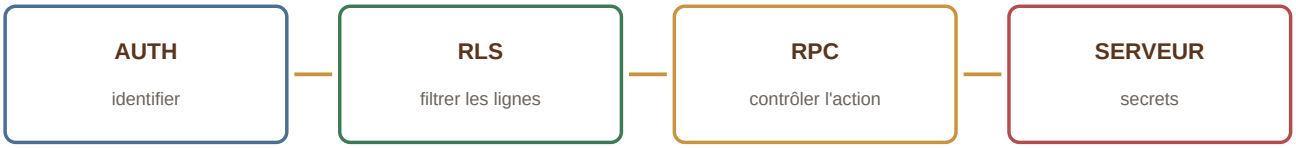
Objectif. Ce document sert de référence technique pour comprendre les protections de Pause Gourmande et vérifier la sécurité avant chaque évolution importante.

Projet	Pause Gourmande — Crêpes & Gaufres artisanales à Lomé
Architecture	React / TanStack Start + Supabase + Netlify
Périmètre	Clients, fidélité, commandes, dashboard administrateur, Push
Principe	Le frontend améliore l'expérience ; Supabase applique les contrôles de sécurité.

1. Les couches de sécurité

La sécurité repose sur plusieurs couches complémentaires : authentification, RLS, fonctions RPC sécurisées et fonctions serveur pour les secrets.

Défense en profondeur



Une vérification uniquement réalisée dans React n'est pas suffisante : un utilisateur peut inspecter le frontend et tenter d'appeler directement les services accessibles au navigateur.

2. RLS : le verrou des tables

RLS (Row Level Security) permet à Supabase de contrôler l'accès aux lignes. Les tables publiques de l'application ont été protégées et les accès directs dangereux ont été remplacés, lorsque nécessaire, par des fonctions contrôlées.

Une requête directe reste soumise à RLS

Règle : une donnée sensible ne doit pas devenir modifiable simplement parce qu'un utilisateur connaît le nom de la table ou de la colonne.

3. Fonctions RPC sécurisées

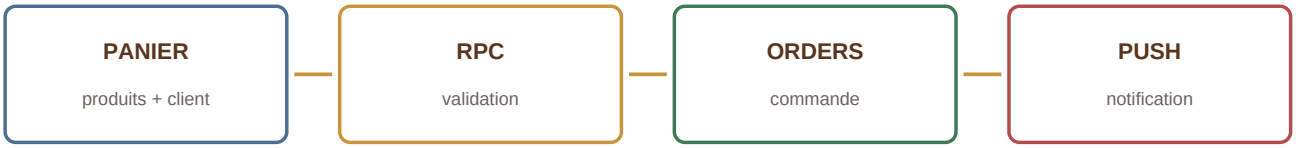
Les opérations métier importantes passent par des fonctions dédiées. Cela permet de valider les paramètres et de concentrer la logique sensible côté base.

Fonction	Rôle
create_customer_secure	Création contrôlée d'un client.
get_customer_by_phone	Recherche client par téléphone.
find_customer_by_referral_code	Recherche contrôlée d'un code de parrainage.
save_customer_reward / get_customer_rewards	Gestion des récompenses via RPC.
has_active_loyalty_reward	Vérification d'une récompense active.
save_wheel_spin / has_played_wheel_today	Contrôle des tours de roue.
add_customer_points	Ajout de points via RPC.
create_order_secure	Création sécurisée d'une commande.

4. Sécurité des commandes

La création d'une commande est une opération métier sensible. Elle peut enregistrer le client, les articles, le total et une récompense utilisée. Elle passe par **create_order_secure** plutôt que par un INSERT public libre.

Flux sécurisé d'une commande

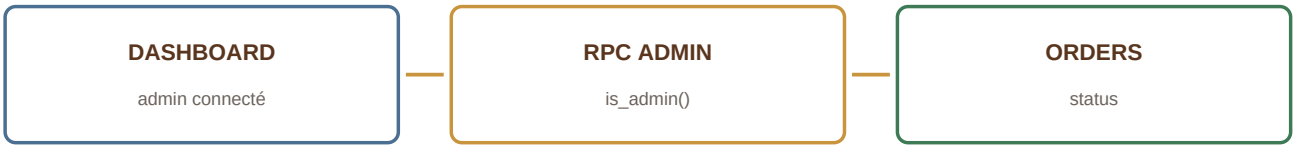


Les informations de récompense utilisées lors de la commande sont également conservées dans la commande : source, valeur et remise.

5. Validation et annulation

Les changements de statut ne doivent pas être réalisés par une mise à jour publique directe. Les opérations administratives utilisent des fonctions sécurisées et vérifient le rôle administrateur.

Une action admin doit être autorisée côté serveur



Le modèle métier retenu est : pending pour une nouvelle commande, done pour une commande validée et cancelled pour une commande annulée.

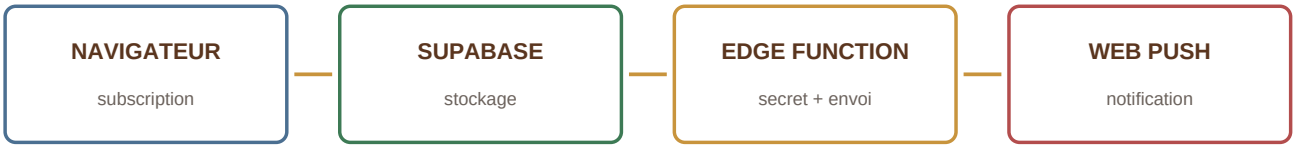
6. Authentification du dashboard

L'accès au dashboard repose sur l'authentification Supabase. La redirection frontend améliore l'expérience, mais les fonctions sensibles doivent également vérifier côté serveur que l'appelant est autorisé.

7. Notifications Push

Les abonnements Push administrateurs et clients sont traités séparément. Les abonnements admin sont liés à un utilisateur authentifié ; les abonnements client sont associés au numéro de téléphone via une RPC dédiée.

Architecture Push



Important : la clé privée VAPID et la Service Role Key doivent rester côté serveur. Elles ne doivent jamais être exposées dans le frontend ou dans Git.

8. Point de vigilance : identité d'un abonnement Push

Un endpoint Push représente un abonnement de navigateur/appareil, pas une identité humaine. Un même appareil peut être utilisé avec différents numéros. La logique d'enregistrement doit donc éviter qu'un simple endpoint soit considéré comme une identité client permanente.

9. iPhone et notifications

Sur iPhone, les notifications Web Push nécessitent l'installation du site sur l'écran d'accueil et l'ouverture depuis cette installation. L'application détecte ce cas et affiche une instruction adaptée au lieu de proposer une activation qui ne fonctionnerait pas dans Safari classique.

Parcours iPhone

10. État des protections

Protection	État documenté
RLS	Activé sur les 11 tables concernées.
customers	Accès direct restreint ; opérations métier via fonctions contrôlées.
Commandes	Création via create_order_secure.
Statuts	Fonctions sécurisées avec contrôle administrateur.
Récompenses / roue / points	RPC sécurisées.
Push admin	Abonnements liés à l'utilisateur authentifié.
Push client	Enregistrement via RPC dédiée.
Edge Function Push	Secrets côté serveur ; webhook protégé.
Audit des permissions RPC	Effectué avec permissions client/admin contrôlées.

11. Checklist avant chaque nouvelle fonctionnalité

■ La nouvelle fonctionnalité expose-t-elle une donnée client ?

■ Une table reçoit-elle de nouvelles lectures, insertions ou modifications ?

■ Les policies RLS restent-elles cohérentes ?

■ Une opération sensible doit-elle devenir une RPC sécurisée ?

■ Une fonction SECURITY DEFINER utilise-t-elle un search_path contrôlé ?

■ Une clé secrète risque-t-elle d'arriver dans le frontend ?

■ Une action admin est-elle vérifiée côté serveur ?

■ Une notification peut-elle être envoyée au mauvais client ?

■ Les points, récompenses ou remises peuvent-ils être falsifiés côté navigateur ?

■ Le changement a-t-il été testé avec un utilisateur non administrateur ?

■ Le changement a-t-il été testé après déploiement en production ?

12. Principe central

L'interface guide l'utilisateur. La base de données protège réellement les données.

Une fonctionnalité est considérée comme correctement sécurisée lorsqu'elle reste protégée même si quelqu'un contourne l'interface, inspecte le JavaScript ou tente d'appeler directement les services Supabase accessibles au client.

Document interne de référence pour Pause Gourmande. À mettre à jour après toute modification importante de Supabase, de l'authentification, des permissions ou des notifications.